Clase 300 — Gobernanza y ética de la IA segura

> Parte: **15 — Seguridad de IA y machine learning** · Fuente: *NIST AI RMF 1.0*, *ISO/IEC 42001:2023* y *EU AI Act* ⏱️ Duración estimada: **100 min** · Nivel: **Avanzado**

🎯 Objetivo

Cerrar la parte llevando todo lo aprendido al plano de la gobernanza: cómo una organización adopta IA de forma segura, responsable y conforme a la regulación. El alumno aprenderá a aplicar NIST AI RMF e ISO/IEC 42001, a clasificar sistemas según el EU AI Act, y a redactar los artefactos de gobernanza clave: política de uso de IA, registro de riesgos y model card.

📚 Resultados de aprendizaje

Al finalizar, el alumno podrá:

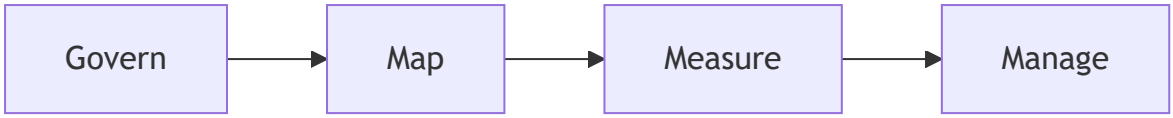
1. **Aplicar** las cuatro funciones del NIST AI RMF (Govern, Map, Measure, Manage) a un sistema real.
2. **Situar** un sistema de IA en las categorías de riesgo del EU AI Act.
3. **Redactar** una política de uso aceptable de IA para una organización.
4. **Elaborar** una model card y una data sheet con consideraciones de seguridad, sesgo y privacidad.
5. **Integrar** la seguridad de IA en el gobierno corporativo (roles, RACI, ciclo de vida).

🗺️ Temas

#	Tema	Por qué importa
1	Por qué gobernar la IA	Alinea seguridad, ética, legal y negocio
2	NIST AI RMF: Govern/Map/Measure/Manage	Marco operativo del riesgo de IA
3	ISO/IEC 42001 (AIMS) e ISO/IEC 23894	Sistema de gestión y gestión del riesgo certificables
4	EU AI Act: niveles de riesgo	Obligaciones legales según el uso
5	Ética: sesgo, equidad, transparencia	Impacto en personas y responsabilidad
6	Model cards y data sheets	Documentación responsable del modelo
7	Roles, RACI y ciclo de vida	Quién responde por qué a lo largo del tiempo

🧠 Explicación en profundidad

Gobernar IA asigna propósito, dueño, riesgo, datos, evaluación, monitorización, incidentes y retiro. NIST AI RMF organiza Govern, Map, Measure y Manage; no prescribe una única puntuación ni convierte ética en cumplimiento automático.



El diagrama debe leerse como una cadena de supuestos: verificar un nodo no demuestra los siguientes. La evaluación declara actor, acceso, datos, métrica, umbral y consecuencia; compara una línea base y conserva fallos, no solo promedios.

Caso razonado

Un modelo pasa exactitud pero carece de mecanismo de apelación. El impacto sobre personas exige controles más allá de performance.

El riesgo económico de la IA: gobernar el consumo, no solo el modelo

La gobernanza de IA suele empezar por el sesgo, la transparencia y la regulación. Hay otro riesgo con un dueño mucho más claro: **el consumo**. Un servicio de IA de pago por uso convierte cualquier credencial en una línea de gasto, y los informes de 2024 a 2026 sobre LLMjacking (clase 295) muestran que ese gasto puede dispararse en horas por obra de un tercero. Una organización que gobierna sus modelos pero no sus claves ni sus límites tiene un hueco de gobierno, aunque tenga una política de IA impecable.

Qué debe tener una gobernanza que lo cubra.

1. **Inventario con dueño.** Cada clave, cuenta de servicio, endpoint y gateway de IA figura en el registro de activos (NIST AI RMF, función *Map*) con un responsable y una fecha de recertificación. Una clave sin dueño no se rota ni se revoca a tiempo.
2. **Apetito de riesgo expresado en dinero.** La política fija un gasto máximo tolerable por servicio y por periodo, y quién puede autorizar excepciones. Esa cifra alimenta los límites técnicos y el análisis cuantitativo de la clase 277. Una cifra pública como los 100 000 USD en un día que menciona GTIG sirve de **escenario de estrés**, no de predicción.
3. **Indicadores de riesgo (KRI) medibles** (función *Measure*): porcentaje de claves con dueño, edad máxima de una clave sin rotar, porcentaje de identidades con límite de gasto, tiempo medio de detección en los ejercicios y cobertura del registro de invocaciones.
4. **Respuesta ensayada** (función *Manage*): el playbook de LLMjacking está en el laboratorio y se ensaya en un tabletop (clase 219). Debe incluir contactos del proveedor, política de preservación de evidencia y quién decide cortar un servicio legítimo si hace falta contener.
5. **Terceros.** El contrato y los términos del proveedor determinan qué ocurre con los cargos fraudulentos: no se supone un reembolso, se verifica con anticipación y se anota como riesgo residual en el registro (clase 284).
6. **Decisión explícita sobre el coste colateral.** Un tope duro protege el presupuesto pero puede interrumpir un servicio legítimo; un tope laxo protege la disponibilidad pero admite más gasto. Esa elección es una decisión del comité de riesgo, no de quien configura la cuota, y debe quedar registrada como aceptación de riesgo.

RACI mínimo. Dueño del servicio (A): aprueba límites y excepciones. Plataforma/FinOps (R): configura cuotas, presupuestos y acciones automáticas. Seguridad (R/C): detección, respuesta y revisión de accesos. Legal/compras (C): términos con el proveedor. Dirección (I): recibe los KRI y las excepciones aceptadas.

Ejemplo. Un equipo de marketing pide ampliar el acceso de una cuenta de servicio a un modelo caro para un lote puntual. Si existe un registro de cambio con ventana, identidad, modelo y tope, la ráfaga se distingue de un abuso en el análisis (escenario S8 del laboratorio) y el tope se amplía solo para esa ventana. Si no existe, se obtiene lo que muestra el laboratorio: o se bloquea trabajo legítimo, o se pierde la señal. La gobernanza es lo que hace posible esa diferencia.

Práctica adicional. Añade al registro de riesgos del reto cuatro filas de consumo de IA (clave expuesta, endpoint sin autenticar, bucle de agente y rampa legítima no coordinada) con probabilidad, impacto en USD según tu escenario de estrés, controles preventivos, detectivos y correctivos, dueño y KRI.

📓 Glosario operativo

Término	Definición
Impact assessment	Evaluación contextual de efectos, afectados y mitigaciones.
KRI	Indicador de riesgo clave: métrica que anticipa que un riesgo se acerca a su apetito.
Apetito de riesgo	Nivel de pérdida que la organización acepta, expresado en términos medibles.
Evaluación	Experimento reproducible ligado a un riesgo y criterio.
Riesgo residual	Exposición que permanece tras controles.

✅ Criterio de dominio

El alumno demuestra dominio cuando formula un escenario específico, reproduce evidencia, explica límites y diseña controles técnicos y de gobierno sin atribuir certeza al modelo.

📖 Definiciones y características

- **Gobernanza de IA:** conjunto de políticas, roles y procesos para que la IA se use de forma segura, ética y conforme. *Característica:* atraviesa seguridad, legal, ética y negocio.
- **NIST AI RMF – Govern:** cultura, políticas y responsabilidades; es transversal a las otras tres funciones (*Map, Measure, Manage*).
- **ISO/IEC 42001:** norma certificable de sistema de gestión de IA (AIMS), análoga a ISO 27001 para seguridad de la información.
- **EU AI Act:** regulación que clasifica los sistemas en riesgo inaceptable (prohibido), alto, limitado y mínimo, con obligaciones crecientes. *Característica:* extraterritorial; afecta a quien opere en la UE.
- **Model card:** documento que describe propósito, datos, desempeño, límites, sesgos y riesgos de seguridad de un modelo (Mitchell et al.).
- **Datasheet for datasets:** documenta origen, composición, sesgos y usos previstos de un dataset (Gebru et al.).
- **Sesgo algorítmico:** desviaciones sistemáticas que perjudican a grupos; requiere medición (equidad) y mitigación. *Característica:* problema técnico y ético a la vez.

🧰 Herramientas y preparación

- **NIST AI RMF Playbook** para acciones sugeridas por función.
- Plantillas de **model card** y **datasheet for datasets**.

- Texto de referencia del **EU AI Act** y guía de **ISO/IEC 42001**.
- Un sistema de IA de caso (real o de las clases anteriores) para gobernar de extremo a extremo.

🧪 Laboratorio guiado (gobernanza aplicada)

Ejercicio documental sobre un **sistema de IA de caso**.

1. **Elige el sistema.** Por ejemplo el asistente RAG de la clase 297 o el detector de anomalías de la 298.
2. **Clasifícalo bajo el EU AI Act.** Determina su categoría de riesgo (inaceptable/alto/limitado/mínimo) y lista las obligaciones asociadas (transparencia, supervisión humana, gestión de riesgos, documentación).
3. **Recorre NIST AI RMF.** - **Map:** contexto, propósito, partes interesadas, riesgos (incluye los técnicos de las clases 291–299). - **Measure:** métricas de desempeño, robustez, sesgo, seguridad (p. ej. tasa de injection exitosa, FPR del detector). - **Manage:** controles priorizados, plan de respuesta, aceptación/transferencia de riesgo. - **Govern:** roles, políticas, RACI, cadencia de revisión.
4. **Redacta una política de uso aceptable de IA.** Qué usos se permiten, qué datos se pueden enviar a modelos externos, revisión humana obligatoria, prohibiciones (datos personales sin base legal, decisiones automáticas de alto impacto).
5. **Elabora la model card.** Propósito, datos, métricas, límites conocidos, sesgos evaluados, riesgos de seguridad y mitigaciones, contacto responsable.
6. **Construye el registro de riesgos.** Tabla: riesgo | probabilidad | impacto | control | dueño | estado, cubriendo al menos 8 riesgos de la parte.
7. **Define el ciclo de vida y RACI.** Quién aprueba el despliegue, quién monitoriza el drift, quién responde ante un incidente de IA. Asigna R/A/C/I.

✍️ Ejercicios

1. Clasifica tres sistemas distintos bajo el EU AI Act y justifica.
2. Mapea 5 riesgos técnicos de las clases 291–299 a las funciones del NIST AI RMF.
3. Redacta 8 cláusulas de una política de uso aceptable de IA generativa.
4. Completa una model card para un modelo que hayas usado en esta parte.
5. Diseña la matriz RACI del ciclo de vida de un modelo de producción.
6. Propón tres métricas de equidad y explica cuándo entran en conflicto.

📝 Reto verificable

Entrega un **paquete de gobernanza de IA** para un sistema concreto que incluya: clasificación EU AI Act justificada, cobertura de las cuatro funciones del NIST AI RMF, una política de uso aceptable, una model card completa y un registro de riesgos con dueños.

Criterio de aceptación: el paquete integra al menos 8 riesgos técnicos vistos en la parte (adversariales, envenenamiento, extracción, prompt injection, excessive agency, etc.), cada uno con un control y un responsable asignado; y la clasificación regulatoria determina obligaciones concretas y verificables. Un comité de riesgo debería poder aprobar o rechazar el despliegue con solo este paquete.

⚠️ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Gobernanza = un documento que nadie usa"	Falta de roles y cadencia. Asigna dueños (RACI) y revisiones periódicas.
Ignorar el EU AI Act por estar fuera de la UE	Es extraterritorial. Si operas con usuarios de la UE, aplica.
Política sin métricas	No se puede gestionar lo que no se mide. Liga cada control a una métrica (Measure).
Model card genérica y vacía	Sin límites ni sesgos declarados. Documenta riesgos de seguridad y equidad reales.
Tratar ética y seguridad por separado	Se solapan (sesgo, transparencia, robustez). Intégralas en un mismo marco.

❓ Preguntas frecuentes

❓ **¿NIST AI RMF e ISO/IEC 42001 compiten?** No. El AI RMF es un marco de gestión de riesgo (voluntario, muy operativo); ISO/IEC 42001 es una norma certificable de sistema de gestión. Muchas organizaciones usan el RMF para operar y la ISO para certificarse.

❓ **¿Toda IA cae bajo el EU AI Act?** No con las mismas obligaciones. El Act es basado en riesgo: los usos de riesgo mínimo tienen cargas ligeras; los de alto riesgo (biometría, crédito, empleo, etc.) tienen requisitos estrictos; algunos usos están prohibidos.

❓ **¿Por qué mezclar seguridad y ética en la misma clase?** Porque comparten problemas: el sesgo es un fallo de integridad; la transparencia habilita la auditoría de seguridad; la robustez protege tanto la seguridad como los derechos de las personas afectadas.

❓ **¿Qué documento entrego primero si tengo prisa?** La model card y el registro de riesgos: dan visibilidad inmediata de límites y controles. La política y la clasificación regulatoria consolidan el marco.

🔗 Referencias

- NIST AI Risk Management Framework 1.0 — https://www.nist.gov/itl/ai-risk-management-framework
- ISO/IEC 42001:2023 (AI management system) — https://www.iso.org/standard/81230.html
- EU AI Act — https://artificialintelligenceact.eu/
- Mitchell et al., "Model Cards for Model Reporting", FAT* 2019 — https://arxiv.org/abs/1810.03993
- Gebru et al., "Datasheets for Datasets", 2018 — https://arxiv.org/abs/1803.09010
- Google Threat Intelligence Group, «The Rise of LLMJacking» (2 de noviembre de 2026) — https://cloud.google.com/blog/topics/threat-intelligence/llmjacking-monetizing-compromised-cloud-models/
- Cloud Security Alliance AI Safety Initiative, «LLMjacking Evolves» (18 de junio de 2026; recomendaciones de gobierno de credenciales de IA) — https://labs.cloudsecurityalliance.org/research/csa-research-note-llmjacking-offensive-ai-tooling-20260618-c/

📥 Material descargable

- 📄 Guía en PDF — versión imprimible de esta clase.
- 🎞️ Presentación (PPTX) — deck para proyectar en clase.

⬅️ Clase anterior

Clase 299 — IA ofensiva y deepfakes

➡️ Siguiente clase

Clase 301 — Roadmap de certificaciones: CompTIA, OSCP, CISSP y más